

Das große Ganze (Warum IT-Sicherheit jeden betrifft)

IT-Sicherheit ist längst kein reines Technik-Thema mehr für Spezialisten im Serverraum, sondern das Fundament jeder modernen Organisation. Wenn IT-Systeme ausfallen oder Daten manipuliert werden, stehen Produktionsbänder still, Krankenhäuser können keine Notfallpatienten versorgen und Unternehmen droht der Ruin. *Wichtiges Grundprinzip:* IT-Sicherheit ist kein fertiges Produkt, das man kauft („wir stellen jetzt eine Firewall hin und sind sicher„), sondern ein permanenter Prozess aus Technik, Organisation und dem Faktor Mensch.

Orientierung & Roter Faden

Diese Einführungsvorlesung spannt den Bogen von einem realen historischen Weckruf (dem ILOVEYOU-Wurm) hin zum wichtigsten theoretischen Denkwerkzeug der gesamten Cybersicherheit: der **CIA-Triade** (Vertraulichkeit, Integrität, Verfügbarkeit). Alle nachfolgenden Vorlesungsthemen (Kryptographie, IAM, Netzwerke, ISMS) bauen direkt auf diesen Schutzzielen auf.

Prüfungsfokus

Die drei Schutzziele der CIA-Triade bilden die absolute Basiskompetenz der Klausur. Du musst sie auf Deutsch und Englisch benennen, voneinander abgrenzen und in vorgegebenen Praxisszenarien (z. B. Webshop, Online-Banking) sofort bestimmen können, welches Schutzziel bedroht oder verletzt wurde.

Inhalte

- CIA-Triade und Grundbegriffe
- Kryptographie
- Identity & Access Management (IAM)
- Secure Software Development Lifecycle (SSDLC)
- Netzwerk- und IoT-Sicherheit
- ISMS - Information Security Management System
- Schwachstellen- und Patchmanagement
- KI-Sicherheit

Strukturüberblick (Der Vorlesungsfahrplan)

Die Vorlesung betrachtet IT-Sicherheit schichtweise von den Grundlagen bis zum Gesamtunternehmen:

- **Kryptographie & IAM:** Die handwerklichen Werkzeuge (Verschlüsselung, Signaturen, Identitätsprüfung).
- **SSDLC:** Sicherheit von Anfang an in Software einbauen statt hinterher flicken (*Security by Design*).
- **Netzwerk, IoT & KI:** Spezifische Technologien und ihre besonderen Angriffsflächen.
- **ISMS & Patchmanagement:** Die organisatorische Klammer, damit Sicherheit im Unternehmen dauerhaft gelebt wird.

Lern-Strategie

- **Fundament (Höchste Priorität):** CIA-Triade, Kryptographie-Grundlagen und Identity & Access Management. Diese Konzepte sind die Vokabeln, ohne die du spätere Themen nicht verstehst.
- **Prozess- & Governance-Ebene:** ISMS, SSDLC und Schwachstellenmanagement erfordern Verständnis von Abläufen und Verantwortlichkeiten (*Defense in Depth*).

Typische Klausurverknüpfung

Prüfer verknüpfen Vorlesungsthemen gerne mit den Schutzzielen: Du musst erklären können, welches CIA-Ziel durch welche Maßnahme geschützt wird (z. B. TLS/Verschlüsselung → Vertraulichkeit; Code Signing/Prüfsumme → Integrität; Server-Redundanz/Cluster → Verfügbarkeit).

Sicherheitsmaßnahmen im Unternehmen

Welche Maßnahmen (Prozesse, Regeln, Tools, Schulungen,...) werden in Ihrem Unternehmen ergriffen, um sich vor IT-Sicherheitsvorfällen zu schützen?

Denkanstoß: Welche Maßnahme verhindert einen Angriff, welche erkennt ihn und welche begrenzt den Schaden?

💡 Auf den Punkt gebracht (Einfach erklärt)

Sicherheit stützt sich nie auf eine einzelne Mauer, sondern auf gestaffelte Verteidigungslinien (**Defense in Depth**). *Alltagsvergleich:* Eine mittelalterliche Burg verlässt sich nicht nur auf das Burgtor. Es gibt einen Wassergraben, eine Zugbrücke, Außenmauern, Fallgitter und den Burgfried. Versagt eine Schicht, hält die nächste den Angreifer auf. Dazu unterscheiden wir Maßnahmen nach ihrem Wirkungszeitpunkt:

1. **Präventiv (Verhindern):** Bevor etwas passiert (z. B. Firewall, Berechtigungsregeln, Mitarbeiterschulung).
2. **Detektiv (Erkennen):** Während etwas passiert (z. B. Einbruchserkennung/IDS, Alarmierung bei Logins nachts um 3 Uhr).
3. **Reaktiv (Beheben):** Nachdem etwas passiert ist (z. B. Notfallplan, befallene Rechner isolieren, Backup einspielen).

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Sicherheitsmaßnahmen den drei Zeitpunkten (präventiv, detektiv, reaktiv) sowie den drei Dimensionen (technisch, organisatorisch, personell / TOMs) fehlerfrei zuordnen.
- **Typische Klausurfalle:** Ein Backup wird oft fälschlicherweise als „präventiv“ bezeichnet. Ein Backup verhindert aber keinen Cyberangriff! Es ist eine **reaktive Maßnahme**, um nach einem Vorfall die Verfügbarkeit der Daten wiederherzustellen.

? Mögliche Klausurfrage & Antwortskizze

Frage: „Nennen Sie für ein Unternehmensnetzwerk je eine technische präventive, eine technische detektive und eine organisatorische reaktive Maßnahme und erläutern Sie kurz deren jeweilige Funktion.“ **Antwort:**

- **Technisch präventiv: Firewall / Multifaktor-Authentifizierung (MFA)** – blockiert unberechtigte Verbindungen bzw. verhindert unbefugten Zugriff im Vorfeld.
- **Technisch detektiv: SIEM / IDS (Intrusion Detection System)** – überwacht Protokolldaten in Echtzeit und schlägt bei verdächtigen Anomalien Alarm.
- **Organisatorisch reaktiv: Incident-Response-Plan (Notfallhandbuch)** – definiert feste Zuständigkeiten und Prozessschritte für das Krisenteam zur schnellen Schadensbegrenzung nach einem Vorfall.

ILOVEYOU

Der Urknall der IT-Sicherheit

Worum geht es in diesem Kapitel? (Der Urknall)

Der Fall ILOVEYOU aus dem Jahr 2000 ist der Prototyp eines verheerenden Sicherheitsvorfalls. Er zeigt eindrucksvoll: Ein Angriff braucht oft gar keine genialen Hackerfähigkeiten, wenn menschliche Neugier, fatale Systemeinstellungen und unbeschränkte Schnittstellen perfekt ineinandergreifen. *Die Kernaussage:* Ein einzelner Faktor hätte die Welt nicht lahmgelegt – erst die unglückliche Kette aus Mensch, Betriebssystem und Mailprogramm führte zur Katastrophe.

Modul-Lernziel

Du verstehst anhand dieses Falls, wie Angreifer Schwachstellenketten (*Kill Chains*) ausnutzen. Du lernst zu analysieren, wo der Mensch manipuliert wurde (Social Engineering), wo die Software versagte (Dateiendungen, fehlende Sandbox) und warum Schnittstellen (APIs) geschützt werden müssen.

Typische Schwerpunkte

In Prüfungen werden Fallstudien als Szenarioaufgaben genutzt: Du musst die einzelnen Stationen der Angriffskette skizzieren und für jede Station begründen können, mit welcher modernen Kontrollmaßnahme man die Kette heute unterbrechen würde.

Steckbrief: VBS.LoveLetter.A

- **Datum:** 4. Mai 2000 (Ausgangspunkt: Philippinen)
- **Schaden & Ausmaß:** 5–10 Mrd. USD Schaden, ~10 % aller Rechner weltweit infiziert
- **Datei & UI-Falle:** LOVE-LETTER-FOR-YOU.TXT.vbs
(Endung .vbs standardmäßig ausgeblendet → wirkte wie .TXT)
- **System:** Windows Script Host (WSH) führte VBScript direkt ohne Sandbox aus

💡 Auf den Punkt gebracht (Einfach erklärt)

Zwei fatale Fehlkonstruktionen machten diesen Wurm weltweit so zerstörerisch:

1. **Die optische Täuschung:** Windows blendete Dateiendungen standardmäßig aus. Aus der gefährlichen Datei LOVE-LETTER-FOR-YOU.TXT.vbs wurde im Dateimanager optisch ein harmloser LOVE-LETTER-FOR-YOU.TXT. Die Nutzer dachten, sie öffnen ein einfaches Textdokument!
2. **Keine Sandbox:** Der *Windows Script Host* führte das VBScript sofort und ohne jede Isolierung mit vollen Benutzerrechten aus – das Skript durfte ungefragt Dateien löschen und E-Mails verschicken. *Alltagsvergleich:* Jemand schickt dir ein Paket mit der Aufschrift „Buchgeschenk,“. Beim Aufmachen entpuppt es sich als automatische Farbbombe, die dein ganzes Haus vollkleckert und sich sofort selbst an alle Kontakte in deinem Notizbuch weiterschickt.

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Den Unterschied zwischen einem **Virus** (benötigt ein Wirtsprogramm/eine Wirtsdatei) und einem **Wurm** (eigenständiges Schadprogramm, verbreitet sich selbstständig über Netzwerke) kennen.
- **Typische Klausurfälle:** Zu behaupten, der Wurm habe eine Sicherheitslücke im Code ausgenutzt. Falsch: Er nutzte *reguläre, vorgesehene Betriebssystemfunktionen* (VBScript, unbeschränkte Script-Ausführung), die schlicht ab Werk unsicher konfiguriert waren!

? Mögliche Klausurfrage & Antwortskizze

Frage: „Grenzen Sie die Begriffe Computerwurm und Computervirus voneinander ab. Erläutern Sie anhand des ILOVEYOU-Steckbriefs, welches Feature des Betriebssystems maßgeblich dazu beitrug, dass Nutzer die Datei bedenkenlos öffneten.“ **Antwort:**

- **Virus vs. Wurm:** Ein Virus heftet sich an eine bestehende Wirtsdatei an und wird nur aktiv, wenn der Wirt gestartet wird. Ein Wurm ist ein eigenständiges Programm, das sich aktiv über Netzwerke und Kommunikationsdienste weiterverbreitet.
- **Betriebssystem-Feature:** Das **automatische Ausblenden bekannter Dateiendungen** in Windows. Dadurch wurde die Skript-Endung .vbs verborgen und die Datei wirkte optisch wie eine harmlose Textdatei (.TXT).

Die Köder-Mail



Abbildung 1: Die Köder-Mail

💡 Auf den Punkt gebracht (Einfach erklärt)

Hier sehen wir ein Paradebeispiel für **Social Engineering** – die gezielte Manipulation menschlicher Verhaltensweisen:

- **Der emotionale Köder:** Neugier und Eitelkeit („Wer gesteht mir hier seine Liebe?“). Wer klickt da nicht?
- **Falsches Vertrauen:** Die E-Mail kam nicht von einem fremden Betrüger, sondern von einem echten Kollegen oder Freund, weil der Wurm dessen Outlook gekapert hatte! *Alltagsvergleich:* Wenn dir ein Fremder auf der Straße einen Zettel zusteckt, bist du misstrauisch. Wenn dir dein bester Freund denselben Zettel in die Hand drückt, liest du ihn sofort. *(Bildhinweis: Zu sehen ist ein Outlook-E-Mail-Fenster mit dem Betreff „ILOVEYOU“, und dem Anhang LOVE-LETTER-FOR-YOU.TXT.vbs mit Skript-Icon).*

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Die psychologischen Faktoren von Phishing analysieren und begründen können, warum reines Awareness-Training (Mitarbeiterschulung) niemals ausreicht, sondern durch technische Barrieren flankiert werden muss.
- **Typische Klausurfalle:** Annehmen, man könne Angriffe allein durch Mitarbeiterschulung verhindern. Menschen machen Fehler – deshalb müssen technische Systeme fehlerverzeihend gebaut sein (*Defense in Depth*).

❓ Mögliche Klausurfrage & Antwortskizze

Frage: „Nennen Sie zwei psychologische Faktoren, die die ILOVEYOU-Mail so erfolgreich machten. Welche moderne technische Maßnahme auf dem E-Mail-Server verhindert heute, dass solche Anhänge überhaupt im Postfach landen?“ **Antwort:**

- **Psychologische Faktoren:**
 1. **Emotionale Neugier / Verlockung:** Reißerischer Betreff („ILOVEYOU“) verleitet zum unüberlegten Klick.
 2. **Vertrauensvorschuss:** Die Mail stammte scheinbar von bekannten Kontakten aus dem persönlichen Adressbuch.
- **Technische Maßnahme: Content-Filtering / Anhänge-Blockade am E-Mail-Gateway:** Gefährliche ausführbare Dateitypen (z. B. .vbs, .bat, .exe) werden serverseitig herausgefiltert oder in einer Quarantäne-Sandbox isoliert.

Funktionsweise des Wurms

- **1. Persistenz:**
 - Schreibt sich in den Registry-Autostart (HKLM\...\Run)
 - Kopiert sich als MSKerne132.vbs ins Windows-Systemverzeichnis
- **2. Schneeball-Verbreitung:**
 - Liest Outlook-Adressbuch (MAPI) aus und mailt sich an alle Kontakte
 - Führt weltweit zum Zusammenbruch von Mail-Servern
- **3. Zerstörung:**
 - Überschreibt Multimediadateien & Skripte (.jpg, .js, ...) mit eigenem Code
 - Versteckt .mp3-Dateien und ersetzt sie durch Wurm-Kopien

💡 Auf den Punkt gebracht (Einfach erklärt)

Der Wurm arbeitete in drei fatalen Schritten:

1. **Persistenz (Einnisten):** Er kopierte sich als angebliche Systemdatei MSKerne132.vbs ins System und trug sich in den Windows-Autostart ein, damit er jeden Computerneustart überlebte.
2. **Schneeball-Effekt (Verbreitung):** Er zapfte die Outlook-Schnittstelle (MAPI) an und verschickte sich an das gesamte Adressbuch – was weltweit Firmen-Mailserver unter der Last zusammenbrechen ließ.
3. **Payload (Zerstörung):** Er überschrieb persönliche Fotos (.jpg), Webdateien und Skripte gnadenlos mit seinem eigenen Code.

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Die drei Phasen (*Persistenz, Verbreitung / Propagation, Payload / Schadwirkung*) unterscheiden und den Auswirkungen die verletzten **CIA-Schutzziele** zuordnen.
- **Typische Klausurfalle:** *Persistenz* mit *Ausführung* verwechseln! Ausführung ist der Doppelklick im Moment; Persistenz bedeutet: Die Schadsoftware bleibt auch nach Herunterfahren und Neustart des Rechners dauerhaft aktiv.

? Mögliche Klausurfrage & Antwortskizze

Frage: „Der ILOVEYOU-Wurm überschrieb lokale Multimediadateien (.jpg) und legte gleichzeitig durch millionenfachen Mailversand E-Mail-Server lahm. Welche zwei Schutzziele der CIA-Triade wurden durch diese beiden Schadwirkungen jeweils verletzt? Begründen Sie kurz.“ **Antwort:**

- **Integrität verletzt:** Durch das Überschreiben der .jpg-Bilder mit Schadcode wurden Originaldaten unwiederbringlich verfälscht und vernichtet (Verlust der Korrektheit und Unversehrtheit).
- **Verfügbarkeit verletzt:** Durch die E-Mail-Flut brachen Mailserver zusammen, sodass legitime Nutzer den Dienst nicht mehr nutzen konnten (Ausfall der Erreichbarkeit/Downtime).

Täter & Rechtliches Nachspiel

- **Täter & Motiv:**
 - Onel de Guzman (24, Informatikstudent in Manila)
 - Ziel: Passwörter für kostenlosen Internetzugang abgreifen
- **Rechtsvakuum:**
 - Keine Cybercrime-Gesetze auf den Philippinen im Mai 2000
 - Weder klassischer Diebstahl noch Sachbeschädigung lag juristisch vor
- **Konsequenz:**
 - Anklage fallen gelassen (*Nulla poena sine lege*)
 - Beschleunigte Verabschiedung des *E-Commerce Act (RA 8792)*

💡 Auf den Punkt gebracht (Einfach erklärt)

Der Programmierer richtete Milliarden Schäden an – wurde aber niemals verurteilt! Warum? Im Mai 2000 gab es auf den Philippinen schlicht kein Gesetz gegen Computer-Kriminalität. Klassischer Diebstahl scheiterte juristisch, weil man Daten nicht wie ein Fahrrad „wegtragen“ kann (Daten sind unkörperlich). Klassische Sachbeschädigung scheiterte, weil die Computer physisch heil blieben. Es griff der fundamentale Rechtsgrundsatz: **„Nulla poena sine lege“** (Keine Strafe ohne Gesetz). Wenn eine Tat zum Zeitpunkt der Ausführung nicht ausdrücklich gesetzlich verboten ist, darf niemand dafür bestraft werden – auch nicht rückwirkend! *Alltagsvergleich:* Wenn es in einer Stadt kein Gesetz gegen das Fahren mit einem elektrischen Hoverboard gibt, kann die Polizei dich nicht bestrafen, egal wie sehr sich andere Fußgänger geärgert haben.

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Das juristische Prinzip *„Nulla poena sine lege“* auf Cybercrime-Vorfälle anwenden und begründen können, warum traditionelle Eigentumsdelikte bei digitalen Daten ohne spezifische IT-Strafgesetze (z. B. § 202a StGB Ausspähen von Daten, § 303a StGB Datenveränderung) scheitern.
- **Typische Klausurfälle:** Argumentieren, dass „doch offensichtlich ein Schaden entstanden ist“. Im Strafrecht gilt ein striktes Analogie- und Rückwirkungsverbot zum Schutz der Bürger.

? Mögliche Klausurfrage & Antwortskizze

Frage: „Warum konnte der Schöpfer des ILOVEYOU-Wurms im Jahr 2000 nicht wegen Diebstahls oder Sachbeschädigung verurteilt werden? Nennen Sie das zugrundeliegende Rechtsprinzip.“ **Antwort:**

- **Rechtsgrundsatz: Nulla poena sine lege** (Keine Strafe ohne vorheriges Gesetz / Verbot von Rückwirkung und strafbegründender Analogie).
- **Begründung:** Klassischer Diebstahl erfordert die Wegnahme einer *körperlichen Sache* (digitale Daten sind unkörperlich). Sachbeschädigung erfordert physische Beschädigung von Gegenständen (Hardware blieb intakt). Da keine speziellen Gesetze gegen Computerviren existierten, war die Tat straffrei.

Fazit & Lehren

- **Secure by Default:** Gefährliche Skripte dürfen nicht standardmäßig per Doppelklick starten
- **UI-Design ist Security:** Das Verstecken von Dateiendungen täuscht Anwender
- **Schnittstellensicherheit:** Unbeschränkter API-Zugriff (wie Outlook MAPI) ist fatal
- **Awareness:** Technik versagt, wenn Nutzer emotional manipuliert werden

Schnell-Check (Die 4 Kernlehren)

1. **Secure by Default:** Ein System muss ab Werk sicher sein – Skripte dürfen nicht einfach per Doppelklick starten!
2. **UI-Design ist Security:** Software darf Nutzer nicht belügen oder täuschen (z. B. Dateiendungen niemals verstecken).
3. **Schnittstellensicherheit (API-Security):** Programme dürfen fremden Code nicht unbeschränkt auf E-Mails oder Kontakte zugreifen lassen.
4. **Awareness & Defense in Depth:** Den Menschen schulen, aber das System so absichern, dass ein Klick nicht die Firma lahmlegt.

Prüfungs-Checkliste

- *Definieren können:* Das Prinzip **Secure by Default** (Sicherheit ist die Werkseinstellung, ohne dass der Nutzer erst manuell Haken setzen muss).
- *Anwenden können:* Zu jeder der 4 Lehren eine moderne Gegenmaßnahme nennen (z. B. Application Allowlisting, Endungsanzeige im Explorer, OAuth-API-Berechtigungen, Phishing-Simulationen).

Blitzfragen zur Selbstkontrolle

Frage 1: Was bedeutet das Sicherheitsprinzip „Secure by Default“, an einem konkreten Beispiel?

Lösung: Eine Software wird in der sichersten Konfiguration ausgeliefert (z. B. Ports standardmäßig geschlossen, Skriptausführung deaktiviert, Standardpasswörter müssen beim ersten Login zwingend geändert werden).

Frage 2: Warum ist das Ausblenden von Dateiendungen im Betriebssystem ein gravierendes Sicherheitsrisiko?

Lösung: Weil Angreifer über doppelte Dateiendungen (z. B. rechnung.pdf.exe) bösartige Programme als harmlose Dokumente tarnen können.

Die CIA-Triade

Schutzziele & Sicherheitsbegriffe

Worum geht es in diesem Kapitel? (Die CIA-Triade)

Jetzt steigen wir in das Herzstück der IT-Sicherheit ein: die **CIA-Triade** (Confidentiality, Integrity, **A**vailability). Sie ist das wichtigste Werkzeug für jeden Sicherheitsverantwortlichen: Egal, welches System du betrachtest – vom Herzschrittmacher bis zum Online-Banking –, mit der CIA-Triade kannst du sofort analysieren: *Was muss hier eigentlich vor wem geschützt werden?*

Modul-Lernziel

Du beherrschst die Definitionen der drei Schutzziele und ihrer Erweiterungen (Authentizität, Zurechenbarkeit), kannst reale Schutzmaßnahmen exakt zuordnen und verstehst, warum die drei Ziele in der Praxis oft in harter Konkurrenz zueinander stehen (*Trade-offs*).

Typische Schwerpunkte

- Die drei Begriffe auf Deutsch und Englisch nennen und definieren.
- Szenario-Zuordnung: Gegeben ist ein Vorfall (z. B. Ransomware, SQL-Injection, DoS-Attacke) → Welches Schutzziel wurde verletzt?
- Die Balance: Zielkonflikte zwischen Vertraulichkeit und Verfügbarkeit erklären (z. B. Notfallzugriff im Krankenhaus).

Angreifer & Motivationen

Wer greift an?

- **Cyberkriminelle:** Finanzieller Profit, RaaS, Erpressung
- **Staaten (APTs):** Spionage, Geopolitik, Sabotage
- **Insider:** Sabotage, Datendiebstahl, Rache
- **Hacktivisten & Script Kiddies:** Protest, Aufmerksamkeit, Spieltrieb

Was sind die Ziele?

- **Finanzen:** Lösegeld (Ransomware), Konten
- **Know-how:** Wirtschaftsspionage, IP-Diebstahl
- **Disruption:** Produktionsausfall, DoS
- **Macht & Kontrolle:** Botnetze, Persistenz

💡 Auf den Punkt gebracht (Einfach erklärt)

Wer greift uns eigentlich an und warum? Sicherheitsexperten müssen das Täterprofil kennen, um die Verteidigung richtig zu dimensionieren:

- **Cyberkriminelle:** Wollen Geld! Sie setzen auf Ransomware oder Erpressung (*Ransomware as a Service*).
- **APTs (Advanced Persistent Threats):** Meist staatlich finanzierte Elite-Spione. Sie haben praktisch unbegrenzte Zeit und Mittel und wollen jahrelang unentdeckt im Netz bleiben.
- **Insider:** Eigene Mitarbeiter. Extrem gefährlich, weil sie schon Schlüssel und Passwörter haben!
- **Script Kiddies / Hacktivisten:** Nutzen fertige Tools aus Neugier, Protest oder Prahlerei. *Achtung Begriffsfall:* **IP-Diebstahl** meint **Intellectual Property** (geistiges Eigentum: Rezepte, Patente, Konstruktionspläne), NICHT die IP-Adresse des Computers!

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Die Angreifergruppen nach Motivation, Ressourcen und typischen Zielen unterscheiden.
- **Typische Klausurfälle:** Eine APT mit einem gewöhnlichen Ransomware-Kriminellen gleichsetzen. APTs wollen **gerade keinen Lärm machen**, sondern unbemerkt spionieren!

❓ Mögliche Klausurfrage & Antwortskizze

Frage: „Was versteht man unter einer APT (Advanced Persistent Threat) und wodurch unterscheidet sich deren Vorgehensweise grundlegend von typischen Ransomware-Cyberkriminellen?“, **Antwort:**

- **Definition APT:** Eine hochgerüstete, oft staatlich geförderte Angreifergruppe mit enormen Ressourcen, die gezielt und über lange Zeiträume in sensible Netze eindringt.
- **Unterschied im Vorgehen:**
 - **Ransomware-Kriminelle:** Machen absichtlich sofort Lärm (Dateien verschlüsseln, Lösegeldforderung anzeigen), um schnell finanziellen Profit zu erzielen.
 - **APTs:** Arbeiten extrem verdeckt (*stealth*), nisten sich dauerhaft ein (*Persistenz*) und wollen über Monate oder Jahre unbemerkt Daten abfließen lassen (Spionage).

Die CIA-Triade – Überblick

- **Confidentiality (Vertraulichkeit):** Schutz vor unbefugter Offenlegung (*Nur wer darf, liest mit*).
- **Integrity (Integrität):** Schutz vor unbefugter Modifikation (*Daten bleiben korrekt & unverfälscht*).
- **Availability (Verfügbarkeit):** Gewährleistung des Zugriffs (*Systeme stehen bei Bedarf bereit*).

💡 Auf den Punkt gebracht (Einfach erklärt)

Die CIA-Triade fasst die drei elementaren Schutzziele zusammen:

- **Confidentiality (Vertraulichkeit):** Nur wer darf, liest mit. Schutz vor neugierigen Blicken (*Geheimhaltung*).
- **Integrity (Integrität):** Daten bleiben korrekt und unverändert. Schutz vor heimlicher Manipulation (*Echtheit & Richtigkeit*).
- **Availability (Verfügbarkeit):** Systeme funktionieren, wenn man sie braucht (*Zuverlässigkeit*). *Alltagsanalogie:* Ein versiegelter Liebesbrief im Umschlag:
 - *Vertraulichkeit:* Niemand öffnet den Umschlag heimlich auf dem Weg.
 - *Integrität:* Niemand radiert Wörter aus oder fälscht den Inhalt.
 - *Verfügbarkeit:* Der Briefträger stellt den Brief rechtzeitig zu, statt ihn in den Papierkorb zu werfen. (*Merkhilfe: Hat nichts mit dem US-Geheimdienst CIA zu tun!*)

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Die 3 Begriffe auf Deutsch und Englisch fehlerfrei nennen und für jede beliebige IT-Anwendung definieren können.
- **Typische Klausurfalle:** Integrität mit Vertraulichkeit verwechseln. Wenn ein Angreifer eine Datenbank manipuliert und Kontostände ändert, verletzt er die **Integrität** (auch wenn er die Daten gar nicht veröffentlicht)!

? Mögliche Klausurfrage & Antwortskizze

Frage: „Nennen Sie die drei Schutzziele der CIA-Triade (Deutsch und Englisch). Welches Schutzziel wird verletzt, wenn ein DoS-Angriff den Webserver einer Fluggesellschaft blockiert?“, **Antwort:**

- **Die drei Schutzziele:**
 1. **Confidentiality** (Vertraulichkeit)
 2. **Integrity** (Integrität)
 3. **Availability** (Verfügbarkeit)
- **Szenario-Zuordnung:** Es wird die **Verfügbarkeit** verletzt, da berechtigte Kunden den Buchungsdienst temporär nicht mehr erreichen können.

C: Vertraulichkeit (Confidentiality)

- **Ziel:** Schutz sensibler Informationen vor unbefugtem Zugriff & Abfluss
- **Verschlüsselung in 3 Zuständen:**
 - *Data in Transit:* TLS, HTTPS, VPN (Schutz vor Abhören / Sniffing)
 - *Data at Rest:* AES-256, BitLocker (Schutz bei physischem Verlust / Diebstahl)
 - *Data in Use:* Secure Enclaves / Confidential Computing
- **Schutzmaßnahmen:**
 - **Least Privilege:** Zugriffsberechtigungen auf das absolute Minimum beschränken
 - **Authentifizierung & MFA:** Strenge Identitätsprüfung vor Freigabe
 - **Klassifizierung:** Öffentlich → Intern → Vertraulich → Streng vertraulich

💡 Auf den Punkt gebracht (Einfach erklärt)

Vertraulichkeit bedeutet: Daten dürfen nicht in falsche Hände geraten. Um Daten zu schützen, muss man ihre drei Lebenszustände kennen:

1. **Data in Transit (unterwegs):** Daten reisen durchs Internet (wie ein Postbrief im Lkw). Schutz: TLS / HTTPS / VPN (verschlossener Briefumschlag).
2. **Data at Rest (gespeichert):** Daten liegen auf Festplatten oder USB-Sticks (wie Akten im Tresor). Schutz: BitLocker / AES-256 (starkes Tresorschloss).
3. **Data in Use (in Bearbeitung):** Daten liegen offen im Arbeitsspeicher der CPU (wie Akten ausgebreitet auf dem Schreibtisch). Schutz: *Confidential Computing* / *Secure Enclaves* (Sichtschutzblende direkt am Prozessor). *Wichtiges Prinzip Least Privilege:* Mitarbeiter bekommen nur exakt die Zugriffsrechte, die sie für ihre aktuelle Arbeit zwingend brauchen – keinen Ordner mehr!

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Die 3 Datenzustände (*in Transit, at Rest, in Use*) nennen, den Unterschied erklären und für jeden Zustand eine konkrete technische Maßnahme angeben.
- **Typische Klausurfalle:** Glauben, dass BitLocker-Festplattenverschlüsselung vor Hackern schützt, während man am PC arbeitet! BitLocker schützt nur im ausgeschalteten Zustand vor Diebstahl des Laptops (*Data at Rest*). Ist Windows gestartet, sind die Daten transparent entschlüsselt.

? Mögliche Klausurfrage & Antwortskizze

Frage: „Erläutern Sie den Unterschied zwischen ‚Data in Transit‘ und ‚Data at Rest‘. Nennen Sie für jeden Zustand eine typische Schutzmaßnahme zur Gewährleistung der Vertraulichkeit.“ **Antwort:**

- **Data in Transit:** Daten befinden sich während der Übertragung über ein Netzwerk in Bewegung (z. B. WLAN, Internet).
Maßnahme: **TLS / HTTPS / VPN** (Transportverschlüsselung).
- **Data at Rest:** Ruhende Daten, die auf einem Speichermedium abgelegt sind (z. B. SSD, Festplatte, Backup-Band).
Maßnahme: **AES-256 / BitLocker** (Festplatten- bzw. Speicherverschlüsselung).

I: Integrität (Integrity)

- **Ziel:** Korrektheit, Vollständigkeit und Unverfälschtheit von Daten & Systemen
- **Kryptographische Schutzmechanismen:**
 - **Kryptographische Hashes (z.B. SHA-256):** Eindeutige Prüfsummen gegen Manipulation
 - **Digitale Signaturen:** Hash + Asymmetrische Kryptographie (Beweis für Urheberschaft & Unversehrtheit)
 - **Code Signing & SBOM:** Schutz der Software-Lieferkette vor Schadcode
- **Systemische Kontrollen:**
 - Schreib-Zugriffskontrolle & strikte Eingabevalidierung (Input Validation)
 - Transaktionssicherheit (ACID) & revisionssicheres Logging

💡 Auf den Punkt gebracht (Einfach erklärt)

Integrität garantiert: Daten sind unverfälscht, vollständig und korrekt. *Alltagsanalogien zur Differenzierung:*

- **Hash-Funktion (Prüfsumme):** Wie ein digitaler Fingerabdruck. Ein Fleischwolf macht aus Fleisch Hackfleisch. Ändert man nur ein Staubkorn im Fleisch, sieht das Hackfleisch völlig anders aus (*Avalanche-Effekt*). Aber: Ein Hash sagt dir NICHT, von wem die Datei stammt!
- **Digitale Signatur:** Ein Wachssiegel mit dem unverkennbaren Siegelring des Absenders. Sie beweist zweierlei: Niemand hat den Text verändert (Integrität) UND der Brief stammt wirklich vom Absender (Authentizität).
- **ACID-Transaktion:** Bei einer Banküberweisung muss das Geld auf Konto A abgebucht UND auf Konto B gutgeschrieben werden. Bricht die Leitung ab, wird alles auf Anfang zurückgesetzt – es geht kein Cent verloren.

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Den Unterschied zwischen einem reinen **Hash** (prüft nur Unverändertheit) und einer **digitalen Signatur** (prüft Unverändertheit + Urheberschaft) erklären können.
- **Typische Klausurfälle:** Einen Hash als „Verschlüsselung“ bezeichnen. Ein Hash ist eine **Einwegfunktion** – man kann aus dem Hash niemals den Originaltext zurückrechnen!

? Mögliche Klausurfrage & Antwortskizze

Frage: „Warum reicht ein bloßer Hashwert (z. B. SHA-256) auf einer Download-Webseite nicht aus, um die Integrität einer Software gegen einen Angreifer im Netzwerk (Man-in-the-Middle) abzusichern? Welche Technologie löst dieses Problem?“, **Antwort:**

- **Problem des einfachen Hashs:** Wenn ein Angreifer den Download-Verkehr manipuliert, kann er die Software mit Schadcode versehen und gleichzeitig den auf der Website angezeigten Hashwert durch den Hash seiner manipulierten Datei ersetzen.
- **Lösung: Digitale Signatur (Code Signing):** Die Datei wird mit dem geheimen privaten Schlüssel des Herstellers signiert. Der Empfänger verifiziert die Signatur über das Zertifikat des Herstellers. Der Angreifer besitzt den privaten Herstellerschlüssel nicht und kann keine gültige Signatur erzeugen.

A: Verfügbarkeit (Availability)

- **Ziel:** Zeitgerechte und verlässliche Erreichbarkeit von Daten und Systemen
- **Wichtige Metriken:**
 - **SLA & Uptime:** 99,9 % (~8,7 h Downtime/Jahr) bis 99,999 % („Five Nines“)
 - **RPO & RTO:** Akzeptabler Datenverlust (RPO) und maximale Wiederanlaufzeit (RTO)
- **Maßnahmen zur Ausfallsicherheit:**
 - **Redundanz:** RAID, Load Balancer, Active/Active-Cluster, Geo-Redundanz
 - **3-2-1-Backup-Regel:** 3 Kopien, 2 verschiedene Medientypen, 1 Offsite (+ Unveränderbarkeit)
 - **DDoS-Abwehr:** Anycast-Netzwerke, Traffic Scrubbing, WAF & Rate Limiting

💡 Auf den Punkt gebracht (Einfach erklärt)

Verfügbarkeit heißt: Systeme und Daten sind genau dann erreichbar, wenn man sie braucht. *Zwei essentielle Kennzahlen für die Notfallplanung:*

- **RPO (Recovery Point Objective):** „Wie viel Datenverlust verkraften wir?“, Maximal tolerierter Zeitraum verlorener Daten (z. B. tägliches Backup um 24:00 Uhr → maximal 24 Stunden Datenverlust bei Crash um 23:59 Uhr).
- **RTO (Recovery Time Objective):** „Wie lange darf die Reparatur dauern?“, Maximal akzeptierte Ausfallzeit bis zum Wiederanlauf des Betriebs (z. B. RTO = 4 Stunden). **Goldene Grundregel: Ein RAID ist KEIN Backup!** Ein RAID spiegelt Festplatten nur im laufenden Betrieb. Wenn ein Mitarbeiter versehentlich eine Datenbank löscht oder Ransomware alles verschlüsselt, wird dieser Fehler im selben Wimpernschlag auf die gespiegelte Platte geschrieben!

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** RPO und RTO an einem Zeitstrahl definieren, die 3-2-1-Backup-Regel erklären (3 Kopien, 2 Medientypen, 1 Kopie außer Haus) und begründen, warum RAID kein Backup ersetzt.
- **Typische Klausurfälle:** RPO und RTO vertauschen: **RPO blickt zurück in die Vergangenheit** (wie alt dürfen die wiederhergestellten Daten sein?); **RTO blickt nach vorn in die Zukunft** (wie viele Stunden dauert der Wiederanlauf?).

? Mögliche Klausurfrage & Antwortskizze

Frage: „Ein IT-Leiter verzichtet auf Backups mit der Begründung: ‚Unsere Server nutzen RAID-1-Spiegelung, wir sind gegen Datenverlust abgesichert.‘ Beurteilen Sie diese Entscheidung kritisch.“ **Antwort:**

- Die Entscheidung ist **fachlich falsch und hochgefährlich**.
- **RAID** bietet lediglich **Hardware-Redundanz** beim Ausfall einzelner Datenträger für den unterbrechungs-freien Betrieb.
- Es bietet **keinen Schutz vor logischen Datenverlusten**: Bei versehentlichem Löschen, Softwarefehlern oder Ransomware-Infektionen wird die Löschung/Verschlüsselung **sofort synchron auf die gespiegelte Platte übertragen**.
- Schutz bietet ausschließlich ein echtes, getrenntes und versionsbasiertes **Backup** (z. B. nach 3-2-1-Regel mit unveränderbarer Kopie).

Der Balanceakt (CIA-Trade-Offs)

Die Schutzziele stehen häufig in natürlicher Konkurrenz:

- **C vs. A:**

Strikte Verschlüsselung & Isolation verlangsamt oder blockiert Zugriff im Notfall.

- **I vs. A:**

Aufwendige Prüfungen und Sperren belasten die Systemperformance.

Beispiel: Ein Notfallzugang verbessert die Verfügbarkeit, kann aber die Vertraulichkeit schwächen. Deshalb braucht er enge Rechte und Protokollierung.

💡 Auf den Punkt gebracht (Einfach erklärt)

In der Realität kann man selten alle drei Schutzziele gleichzeitig auf Anschlag drehen – sie stehen oft in natürlicher Konkurrenz zueinander (**Trade-offs**):

- **Vertraulichkeit vs. Verfügbarkeit (C vs. A):** Je mehr Passwörter, MFA-Abfragen und Verschlüsselungsschichten ich einbaue (maximale Vertraulichkeit), desto langsamer und umständlicher wird der Zugriff im Notfall (Verfügbarkeit leidet). *Klassiker im Krankenhaus (Das „Break-Glass“-Prinzip):* Wenn ein Patient in der Notaufnahme reanimiert wird, darf der Notarzt nicht erst 10 Minuten auf Freigaben für die Patientenakte warten. Die Verfügbarkeit hat hier absolute Priorität! Der Notarzt darf die Akte per Notfall-Knopf sofort öffnen. *Die Lösung des Konflikts:* Wir lockern die Vertraulichkeit für den Notfall, sichern uns aber durch **revisionssichere Protokollierung (Logging)** ab – jeder Notfallzugriff wird registriert und im Nachgang zwingend auditiert.

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Den Zielkonflikt zwischen Vertraulichkeit und Verfügbarkeit an einem praktischen Szenario erläutern und erklären, wie **kompensierende Maßnahmen** (z. B. Audit-Logs) den Konflikt lösen.
- **Typische Klausurfälle:** Annehmen, dass Vertraulichkeit *immer* das wichtigste Ziel sei. Im medizinischen Notfall oder bei industriellen Steuerungsanlagen (z. B. Kraftwerk) steht **Verfügbarkeit** über allem!

? Mögliche Klausurfrage & Antwortskizze

Frage: „Erläutern Sie den Zielkonflikt zwischen Vertraulichkeit und Verfügbarkeit am Beispiel des Notfallzugriffs („Break-Glass“) im Krankenhaus. Welche Sicherheitsmaßnahme kompensiert die vorübergehend gelockerte Vertraulichkeit?“, **Antwort:**

- **Zielkonflikt:** Strikte Zugriffskontrollen schützen Patientendaten vor unbefugter Einsicht (Vertraulichkeit), verhindern im akuten Lebensnotfall aber schnellen Datenzugriff für das medizinische Personal (Verfügbarkeit).
- **Kompensierende Maßnahme: Vollständiges, revisionssicheres Logging / Auditing:** Der Notfallzugriff wird mit Zeitstempel, Benutzer-ID und Begründung protokolliert und löst eine Benachrichtigung an den Datenschutzbeauftragten zur nachträglichen Prüfung aus.

Erweiterte Schutzziele

Moderne Sicherheitsmodelle ergänzen die CIA-Triade um zwei Kernaspekte:

- **Authentizität (Authenticity):**
 - *Echtheit der Identität und des Ursprungs*
 - „Bist du wirklich derjenige, für den du dich ausgibst?“, (MFA, Zertifikate)
- **Zurechenbarkeit / Nicht-Abstreitbarkeit (Non-Repudiation):**
 - *Beweiskraft von Handlungen*
 - Niemand kann eine getätigte Transaktion leugnen (Signaturen, Audit-Logs)

Einordnung: CIA beschreibt drei grundlegende Schutzziele; Authentizität und Zurechenbarkeit ergänzen das Modell, ersetzen es aber nicht.

💡 Auf den Punkt gebracht (Einfach erklärt)

Die klassische CIA-Triade wird in der modernen Praxis um zwei wesentliche Schutzziele erweitert:

1. **Authentizität (Echtheit):** Ist der Absender wirklich der, für den er sich ausgibt?
Alltagsvergleich: Jemand zeigt dir an der Tür seinen echten Personalausweis vor.
2. **Zurechenbarkeit / Nicht-Abstreitbarkeit (Non-Repudiation):** Niemand kann eine getätigte Aktion hinterher leugnen.
Alltagsvergleich: Ein notariell beglaubigter Vertrag oder ein Einschreiben mit Rückschein. Wenn du im Online-Banking 5.000 € überweist, darfst du hinterher nicht behaupten: „Das war ich nicht, das System hat gesponnen!“, *Die 3 magischen A-Begriffe (Häufige Verwechslungsgefahr!):*
 - **Authentisierung:** Du weist deine Identität nach (z. B. Passwort eingeben, Fingerabdruck auflegen).
 - **Authentifizierung:** Das System überprüft deinen Nachweis (Passwort-Hash prüfen).
 - **Autorisierung:** Das System weist dir Rechte zu (was darfst du tun? z. B. Leserechte ja, Löschrechte nein).

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Authentizität und Nicht-Abstreitbarkeit definieren und die Begriffskette *Authentisierung* → *Authentifizierung* → *Autorisierung* trennscharf an einem Beispiel (z. B. Login im Portal) erklären.
- **Typische Klausurfälle:** Authentifizierung mit Autorisierung verwechseln! Einloggen ist Authentifizierung; prüfen, ob du Admin-Rechte hast, ist Autorisierung.

? Mögliche Klausurfrage & Antwortskizze

Frage: „Unterscheiden Sie die Begriffe Authentifizierung und Autorisierung anhand eines Online-Banking-Systems. Erläutern Sie zudem, was unter Nicht-Abstreitbarkeit (Non-Repudiation) verstanden wird.“

„**Antwort:**“

- **Authentifizierung:** Prüfung der Identität des Anwenders beim Login (z. B. Benutzername + Passwort + Bestätigung in der Banking-App).
- **Autorisierung:** Festlegung und Prüfung der erlaubten Aktionen nach erfolgreicher Authentifizierung (z. B. Darf Kontostände einsehen und Überweisungen bis zum Tageslimit tätigen, aber keine fremden Konten verwalten).
- **Nicht-Abstreitbarkeit (Non-Repudiation):** Technische und rechtliche Unanfechtbarkeit einer ausgeführten Handlung (z. B. durch digitale Signaturen und manipulationssichere Transaktionsprotokolle), sodass der Urheber die Durchführung nicht glaubhaft leugnen kann.